

Web Application Security

امن تطبيقات الويب

Dr. Fawaz Al-Ghfari

Who am I?

Name:	Dr. FAWAZ MOKBAL
Field of Specialization	PhD Computer Science and Technology (AI for Cybersecurity).
Academic Qualifications	Doctor of Engineering , Computer Science and Technology, Beijing University of Technology, Beijing, China. Master of Information Technology , Network Security, The University of Agriculture, CS&IT, Peshawar, Pakistan. Bachelor of Computer Science ,
Research Interests	• Brain-Computer interface -Electroencephalography (BCI-EEG) • Web Applications Security. • Internet of Things (IoT) Security. • Machine learning & Deep Learning Intersection with Cybersecurity. • Data Science and Data Modeling. • High Dimension Reduction & Feature Selection. • Ad-hoc Networks Security.
Contact Information	fawazalghfari@gmail.com
Webpage	Google scholar , ResearchGate , LinkedIn

Books & Website

- 1. Mike Harwood, Ron Price, 2022, Internet and Web Application Security, 3rd Edition, USA, Jones & Bartlett Learning
- 1. Andrew Hoffman, 2023, Web Application Security: Exploitation and Countermeasures for Modern Web Applications, 2nd Edition, USA, O'Reilly Media
- <https://www.invicti.com/blog/web-security/getting-started-web-application-security/>

تقسيم الدرجات

التقييم				
نوع التقييم	نظري	تطبيقي	المجموع	
الاختبار النصفى	٢٠	١٠	٣٠	
الاختبار النهائى	٤٠	٢٠	٦٠	
التكاليف والنشاط والحضور	١٠	١٠	١٠	
المجموع	٧٠	٣٠	١٠٠	

General Course Objectives

- Understand fundamental web application architecture and HTTP/HTTPS protocols
- Identify common cyber attacks and their operational mechanisms
- Learn multi-layered defense and protection strategies
- Apply security concepts in various web development environments
- Master security tools for detection, prevention, and response
- Develop vulnerability analysis and risk assessment skills
- Understand future security trends and emerging challenges

الأهداف العامة

- فهم البنية الأساسية لتطبيقات الويب وبروتوكولات HTTP/HTTPS
- التعرف على أشهر الهجمات الإلكترونية وآليات عملها
- تعلم استراتيجيات الدفاع والحماية متعددة الطبقات
- تطبيق مفاهيم الأمان في بيئات تطوير الويب المختلفة
- إتقان استخدام أدوات الأمان للكشف والمنع والاستجابة
- تطوير مهارات تحليل الثغرات وتقييم المخاطر
- فهم اتجاهات الأمان المستقبلية والتحديات الناشئة

Introduction

- Many sensitive tasks are done through the web
 - Online banking, online shopping
 - Database access
 - System Administration
- يتم تنفيذ العديد من المهام الحساسة عبر الويب
 - الخدمات المصرفية عبر الإنترنت،
 - والتسوق عبر الإنترنت
 - الوصول إلى قاعدة البيانات
 - إدارة النظام

Introduction con..

- Web application security is the practice of protecting websites, applications, and APIs from attacks. It is a broad discipline, but its ultimate aims are keeping web applications functioning smoothly and protecting businesses from cyber vandalism, data theft, unethical competition, and other negative consequences.
- The global nature of the Internet exposes web applications and APIs to attacks from many locations and various levels of scale and complexity. As such, web application security encompasses a variety of strategies and covers many parts of the software supply chain.

- أمان تطبيقات الويب هو ممارسة حماية مواقع الويب والتطبيقات وواجهات برمجة التطبيقات من الهجمات. إنه مجال واسع، لكن **أهدافه النهائية** هي الحفاظ على عمل تطبيقات الويب بسلاسة وحماية الشركات من التخريب الإلكتروني وسرقة البيانات والمنافسة غير الأخلاقية والعواقب السلبية الأخرى.

- تعرض الطبيعة العالمية للإنترنت تطبيقات الويب وواجهات برمجة التطبيقات (APIs) للهجمات من العديد من المواقع ومستويات مختلفة من الحجم والتعقيد. على هذا النحو،

- يشمل أمان تطبيقات الويب مجموعة متنوعة من الاستراتيجيات ويغطي أجزاء كثيرة من سلسلة توريد البرامج.

Introduction Con...

- Web applications, like all software, inevitably contain defects. Some of these defects constitute actual vulnerabilities that can be exploited, introducing risks to organizations. Web application security defends against such defects. It involves leveraging secure development practices and implementing security measures throughout the software development life cycle (SDLC), ensuring that design-level flaws and implementation-level bugs are addressed.
- تطبيقات الويب، مثل جميع البرامج، **تحتوي حتماً على عيوب**. وتشكل بعض هذه العيوب نقاط ضعف فعلية يمكن استغلالها، مما يعرض المؤسسات لمخاطر.
- **يدافع** أمان تطبيقات الويب ضد مثل هذه العيوب.
- أمان تطبيقات ينطوي على الاستفادة من **ممارسات التطوير الآمنة وتنفيذ التدابير الأمنية** طوال **دورة حياة تطوير البرمجيات** (SDLC)
- **يضمن** :
 - معالجة العيوب على مستوى التصميم
 - والأخطاء على مستوى التنفيذ.

What are the different types of security tests?

ما هي الأنواع المختلفة للاختبارات الأمنية؟

- **Dynamic Application Security**

Test (DAST). This automated application security test is best for internally facing, low-risk applications that must comply with regulatory security assessments. For medium-risk applications and critical applications undergoing minor changes, combining DAST with some manual web security testing for common vulnerabilities is the best solution.

- اختبار أمان التطبيقات **الديناميكي** (DAST) يعد اختبار أمان التطبيق الآلي هذا هو الأفضل للتطبيقات **منخفضة المخاطر** التي تواجه الداخل والتي يجب أن تتوافق مع تقييمات الأمان التنظيمية.
- بالنسبة للتطبيقات متوسطة المخاطر والتطبيقات الهامة التي تخضع لتغييرات طفيفة، فإن الجمع بين DAST وبعض اختبارات أمان الويب اليدوية لنقاط الضعف الشائعة هو الحل الأفضل.

What are the different types of security tests?

ما هي الأنواع المختلفة للاختبارات الأمنية؟

- **Static Application Security Test (SAST).**

This application security approach offers automated and manual testing techniques. It is best for identifying bugs without the need to execute applications in a production environment. It also enables developers to scan source code and systematically find and eliminate software security vulnerabilities.

- اختبار أمان التطبيقات **الثابتة** (SAST)

- يوفر نهج أمان التطبيقات هذا تقنيات اختبار **آلية ويدوية**.

- إنه الأفضل لتحديد الأخطاء دون الحاجة إلى تنفيذ التطبيقات في بيئة الإنتاج.

- كما أنه يمكن المطورين من فحص التعليمات البرمجية المصدر والعثور بشكل منهجي على الثغرات الأمنية في البرامج وإزالتها.

.

What are the different types of security tests?

ما هي الأنواع المختلفة للاختبارات الأمنية؟

- **Penetration Test**. This manual application security test is best for critical applications, especially those undergoing major changes. The assessment involves business logic and adversary-based testing to discover advanced attack scenarios.
- **Runtime Application Self Protection (RASP)**. This evolving application security approach encompasses a number of technological techniques to instrument an application so that attacks can be monitored as they execute and, ideally, blocked in real time.

- **اختبار الاختراق**. يعد اختبار أمان التطبيقات اليدوي هذا هو الأفضل للتطبيقات **المهمة**، خاصة تلك التي تخضع لتغييرات كبيرة. يتضمن التقييم منطق الأعمال والاختبار القائم على الخصم لاكتشاف سيناريوهات الهجوم المتقدمة.
- الحماية الذاتية لتطبيق وقت التشغيل (RASP) يشمل هذا النهج المتطور لأمن التطبيقات عددًا من التقنيات التكنولوجية لتجهيز التطبيق بحيث يمكن مراقبة الهجمات أثناء تنفيذها، ومن الناحية المثالية، **حظرها في الوقت الفعلي**.

How does application security testing reduce your organization's risk?

- **Majority of Web Application Attacks**

- SQL Injection
- XSS (Cross-Site Scripting)
- Cross-site request forgery
- Information leakage
- Session hijacking
- Path Traversal

- **Attack Results**

- Access to restricted content
- Compromised user accounts
- Installation of malicious code
- Lost sales revenue
- Loss of trust with customers
- Damaged brand reputation
- And much more

- هجمات تطبيقات الويب الشائعة

- حقن SQL
- البرمجة النصية عبر المواقع XSS
- تزوير عبر الموقع
- تسرب المعلومات
- اختطاف الجلسة
- اجتياز المسار

- نتائج الهجوم

- الوصول إلى المحتوى المقيد
- حسابات المستخدمين المخترقة
- تثبيت التعليمات البرمجية الضارة
- خسارة إيرادات المبيعات
- فقدان الثقة مع العملاء
- سمعة العلامة التجارية المتضررة
- وأكثر بكثير

How does application security testing reduce your organization's risk?

- Knowing the different attacks that make an application vulnerable, in addition to the potential outcomes of an attack, allows your firm to preemptively address the vulnerabilities and accurately test for them.

• إن معرفة الهجمات المختلفة التي تجعل التطبيق عرضة للخطر، بالإضافة إلى النتائج المحتملة للهجوم، يسمح لنا بمعالجة نقاط الضعف بشكل استباقي واختبارها بدقة.

- By identifying the root cause of the vulnerabilities, mitigating controls can be implemented during the early stages of the SDLC to prevent any issues.
- Additionally, knowledge of how these attacks work can be leveraged to target known points of interest during a Web application security test.

• من خلال تحديد السبب الجذري لنقاط الضعف، يمكن تنفيذ ضوابط التخفيف خلال المراحل المبكرة من دورة حياة تطوير البرمجيات (SDLC) لمنع أي مشاكل.

• يمكن الاستفادة من معرفة كيفية عمل هذه الهجمات لاستهداف نقاط الاهتمام المعروفة أثناء اختبار أمان تطبيق الويب.

How does application security testing reduce your organization's risk?

- Recognizing the impact of an attack is also key to managing your firm's risk, as the effects of a successful attack can be used to gauge the vulnerability's total severity. If issues are identified during a security test, defining their severity allows your firm to efficiently prioritize the remediation efforts. Start with critical severity issues and work towards lower impact issues to minimize risk to your firm.
- يعد التعرف على تأثير الهجوم أيضًا أمرًا أساسيًا لإدارة مخاطر شركتك، حيث يمكن استخدام تأثيرات الهجوم الناجح لقياس مدى خطورة الثغرة الأمنية.
- إذا تم تحديد المشكلات أثناء اختبار الأمان، فإن تحديد مدى خطورتها يسمح لشركتك بتحديد أولويات جهود الإصلاح بكفاءة. (الدرجة أولاً)

What features should be reviewed during a web application security test?

- تكوين التطبيق والخادم. ترتبط العيوب المحتملة بتكوينات التشفير/التشفير، وتكوينات خادم الويب، وما إلى ذلك.
- التحقق من صحة الإدخال ومعالجة الأخطاء. إن حقن SQL والبرمجة النصية عبر المواقع (XSS) وغيرها من ثغرات الحقن الشائعة هي نتيجة لسوء التعامل مع المدخلات والمخرجات.
- المصادقة وإدارة الجلسة. من المحتمل أن تؤدي الثغرات الأمنية إلى انتحال هوية المستخدم. وينبغي أيضا النظر في قوة الاعتماد والحماية.
- Application and server configuration. Potential defects are related to encryption/cryptographic configurations, Web server configurations, etc.
- Input validation and error handling. SQL injection, cross-site scripting (XSS), and other common injection vulnerabilities are the result of poor input and output handling.
- Authentication and session management. Vulnerabilities potentially result in user impersonation. Credential strength and protection should also be considered.

What features should be reviewed during a web application security test?

- Authorization. Testing the ability of the application to protect against vertical and horizontal privilege escalations.
- Business logic. These are important to most applications that provide business functionality.
- Client-side logic. With modern, JavaScript-heavy webpages, in addition to webpages using other types of client-side technologies (e.g., Silverlight, Flash, Java applets), this type of feature is becoming more prevalent.
- تفويض. اختبار قدرة التطبيق على الحماية من **تصعيد الامتيازات الرأسية والأفقية**.
 - مدى قدرة تطبيق معين على منع المستخدمين غير المصرح لهم من الوصول إلى مستويات أعلى من تلك التي يحق لهم الوصول إليها.
 - يُعرف تصعيد الامتيازات الرأسية بأنه عندما يحصل المستخدم على وصول على مستوى أعلى داخل نفس السياق الأمني،
 - بينما يعني تصعيد الامتيازات الأفقية الوصول إلى نفس المستوى ولكن في سياقات مختلفة.
- منطق الأعمال. تعتبر هذه العناصر مهمة لمعظم التطبيقات التي توفر وظائف الأعمال.
- المنطق من جانب العميل. مع صفحات الويب الحديثة التي تعتمد على جافا سكريبت، بالإضافة إلى صفحات الويب التي تستخدم أنواعًا أخرى من التقنيات من جانب العميل (مثل Silverlight وFlash وتطبيقات Java الصغيرة)، أصبح هذا النوع من الميزات أكثر انتشارًا.